16·05·2025 (E)

SOMAIYA VIDYAVIHAR UNIVERSITY

Semester: January 2025 –April 2025		
Maximum Marks: 100	**Examination: ESE Examination**	**Duration:3 Hrs.**
Programme code: 55 **Programme: Cyber Security & Forensics (Honors)**	**Class: T.Y.B.Tech**	**Semester: VI (SVU 2020)**
Institute/School/Department: K. J. Somaiya School of Engineering	**Name of the department:** Computer Engineering	
Course Code: 116h55C601	**Name of the Course: Vulnerability Assessment & Penetration Testing**	
Instructions: 1)Draw neat diagrams 2) All questions are compulsory 3) Assume suitable data wherever necessary		

Que. No.	Question	Max. Marks
Q1	Solve *any* **Four**	**20**
i)	Mention five relevant points of difference between vulnerability assessment & penetration testing.	5
ii)	Write the importance of the rules of engagement in penetration testing.	5
iii)	What is WHOIS and how is it useful during reconnaissance?	5
iv)	Briefly explain the function of payloads in exploits.	5
v)	What is the primary purpose of an SSL Stripping attack in the context of MITM attacks? Explain.	5
vi)	Differentiate between red teaming and penetration testing.	5

Que. No.	Question	Max. Marks
Q2 A	Solve the following	**10**
i)	An educational institute wants to pen test their internal network. Design a basic test plan for the same with brief mention of scope, objectives, tools and expected deliverables.	5
ii)	Considering the situation of pen testing of internal network of an educational institute, what risks are involved in performing a penetration test on a live internal network? How can they be mitigated?	5
	OR	
Q2 A	You are assigned to perform recon on a company's domain *example.com*. Describe the steps you would take in the information gathering phase. Mention at least two tools that would assist in information gathering.	10
Q 2 B	Solve *any* **One**	**10**
i)	A scan was performed using Nmap w.r.t the following: PORT STATE SERVICE 22/tcp open ssh 80/tcp open http 443/tcp open https 3306/tcp open mysql Interpret the outcome of the above mentioned commands.	10

ii)	You're tasked with conducting a black-box vulnerability assessment and pen testing against a mid-sized financial institution. You are only given the name of the company: SecureBank Ltd. Answer the following questions w.r.t. the above assessment: (a) List the passive reconnaissance techniques to be used for information gathering without touching their infrastructure. (b) Mention the tools/platforms required to gather this information. (c) How would you carry out domain and sub-domain enumeration?	10

Que. No.	Question	Max. Marks
Q3	Solve *any* **Two**	**20**
i)	What role does CVE (Common Vulnerabilities and Exposures) play in identifying exploits? List any five CVE's found in operating systems.	10
ii)	What do you understand by privilege escalation exploits? Explain different types of privilege escalation.	10
iii)	Discuss with the help of a suitable scenario in which tokenization can help reduce the risk of sensitive data exposure during a penetration test. Justify your answer.	10

Que. No.	Question	Max. Marks
Q4	Solve *any* **Two**	**20**
i)	List the difference between a reverse shell and a bind shell. Explain any method for establishing a reverse shell.	10
ii)	With the help of supporting diagram, illustrate the working of metasploit framework.	10
iii)	Outline the process of validating and documenting vulnerability in a report with supporting example.	10

Que. No.	Question	Max. Marks
Q5	Solve *any* **four**	**20**
i)	Trade-off between ethics & laws.	5
ii)	OSINT framework.	5
iii)	Fuzzing & Obfuscation.	5
iv)	CVSS.	5
v)	Incidence-Response.	5
vi)	Purple teaming in security.	5